

An IAM flow

ID: e6821066-576c-47b2-89c8-69bf131e439b State: COMPLETE Exported: 2026-06-09 19:57 UTC

Type: hybrid

Executive summary

This architecture diagram illustrates an **IAM Role Change Flow** across three logical zones: Internet, Internal Network, and Identity Services.

The flow begins in the **Internet** zone, where a user initiates a "Login / Access Request" via a **User Browser**. This request hits the **Web Portal** in the **Internal Network**, which acts as a proxy, forwarding an **API Request** to the **API Gateway**.

The Gateway acts as the central orchestrator: it requests token validation and claim retrieval from the **IAM Service/IAP** (Identity Services). The IAM Service interacts with a **User Directory/LDAP** to fetch group data and may trigger an **MFA Challenge** via an external **MFA Provider**.

Simultaneously, the Gateway communicates with a **Policy Store** to read roles and policies. When an administrator uses the **Admin Console** to "Update Roles" or "Change Policy," the changes are pushed directly to the Policy Store. Finally, all **Access Decisions** and **Auth Events** are captured in a centralized **Audit Log** for compliance and monitoring.

Assets & entities

TYPE	NAME	CRITICALITY	DESCRIPTION
Asset	System Overview	Medium	This architecture diagram illustrates an IAM Role Change Flow across three logical zones: Internet, Internal Network, and Identity Services. The flow begins in the Internet zone, where a user initiates a "Login / Access Request" via a User Browser . This request hits the Web Portal

Data flows

SOURCE	TARGET	DESCRIPTION
User Browser	Web Portal	User submits login credentials/access request.
Web Portal	API Gateway	Forwarded API request containing user credentials/context.
API Gateway	IAM Service/IAP	Request for token validation and claim retrieval.
IAM Service/IAP		Request for user group data and attributes.

SOURCE	TARGET	DESCRIPTION
	User Directory/ LDAP	
IAM Service/IAP	MFA Provider	Outbound request to trigger multi-factor authentication.
API Gateway	Policy Store	Request to fetch roles and permissions policies.
Admin Console	Policy Store	Push of updated roles or modified policies.
API Gateway / IAM Service	Audit Log	Streaming of access decisions and authentication events.

Threat actors

CATEGORY	DESCRIPTION	EXAMPLES
External Adversaries	Malicious actors seeking to gain unauthorized access to the internal network or escalate privileges.	Script Kiddies, Hacktivists, State-sponsored actors
Malicious Insiders	Employees or contractors with legitimate access who abuse their privileges to exfiltrate data or change policies.	Disgruntled employees, compromised internal accounts
Credential Thieves	Actors who steal user credentials (via phishing or stuffing) to bypass initial login barriers.	Botnets, Phishing kits
Compromised Admin	An attacker who has successfully hijacked an Administrator account to modify the Policy Store directly.	Account Takeover (ATO) attackers
Third-Party Risk	Potential compromise or downtime of the external MFA Provider affecting availability or trust.	Supply chain attackers

Threat catalog (STRIDE)

TOTAL THREATS

20

Credential Theft via Web Portal

SPOOFING

MEDIUM

External Adversaries, via a Man-in-the-Middle (MitM) or XSS attack on the User Browser, can intercept user login credentials which leads to unauthorized account access, negatively impacting the User Directory/LDAP.

Target: User Directory/LDAP · **Source:** User Browser

Vector: Network / Web Application

Impact: High

Mitigations: Enforce TLS 1.3 for all connections; Implement Content Security Policy (CSP); Use HttpOnly and Secure flags for cookies; Implement HSTS

Policy Store Manipulation by Malicious Insider

TAMPERING

LOW

Malicious Insiders, with access to the internal network, can bypass the Admin Console and directly modify the Policy Store which leads to unauthorized privilege escalation for specific users, negatively impacting the System Overview.

Target: Policy Store · **Source:** Internal Network

Vector: Internal Network

Impact: Critical

Mitigations: Implement strict network segmentation (Micro-segmentation); Use Mutual TLS (mTLS) for all internal service communications; Apply 'Least Privilege' to the database/store accounts; Implement File Integrity Monitoring (FIM) or database triggers for policy changes

Audit Log Deletion by Compromised Admin

REPUDIATION

LOW

Compromised Admin, with high-level permissions, can delete or modify entries in the Audit Log which leads to an inability to perform forensic analysis or meet compliance requirements, negatively impacting the System Overview.

Target: Audit Log · **Source:** Admin Console

Vector: Administrative Access

Impact: High

Mitigations: Implement WORM (Write Once Read Many) storage for logs; Stream logs in real-time to a separate, isolated logging environment; Strictly separate Audit Log access from Admin Console permissions

MFA Provider Response Spoofing

SPOOFING

LOW

External Adversaries, via a DNS hijack or compromised outbound route, can spoof a 'Success' response from the MFA Provider which leads to authentication bypass, negatively impacting the IAM Service/IAP.

Target: IAM Service/IAP · **Source:** MFA Provider

Vector: Third-Party Risk

Impact: Critical

Mitigations: Validate MFA responses using signed JWTs or HMAC; Use IP allowlisting for the MFA Provider's callbacks; Implement certificate pinning for outbound requests

Policy Store Exhaustion (DoS)

DENIAL OF SERVICE

MEDIUM

External Adversaries, via a flood of API requests to the Gateway, can overwhelm the Policy Store's query capacity which leads to a system-wide lockout or failure to authorize legitimate users, negatively impacting the Web Portal.

Target: Policy Store · **Source:** API Gateway

Vector: Network

Impact: Medium

Mitigations: Implement Rate Limiting and Throttling at the API Gateway; Use a caching layer (e.g., Redis) for frequently accessed policies; Implement circuit breakers between Gateway and Policy Store

Token Claim Injection

ELEVATION OF PRIVILEGE

MEDIUM

Credential Thieves, by capturing a valid but weakly scoped token, can manipulate internal claims during the Gateway-to-IAM exchange which leads to unauthorized role assignment, negatively impacting the System Overview.

Target: IAM Service/IAP · **Source:** API Gateway

Vector: API Request

Impact: High

Mitigations: Use short-lived access tokens; Implement strict claim validation on the IAM Service side; Use cryptographically signed tokens (JWS/JWT); Implement audience (aud) and issuer (iss) checks

Credential Stuffing on Web Portal

SPOOFING

HIGH

External Adversaries, with automated botnets, can brute-force user credentials on the Web Portal which leads to unauthorized account access, negatively impacting the User Directory/LDAP.

Target: User Directory/LDAP · **Source:** User Browser

Vector: Internet

Impact: High

Mitigations: Implement rate limiting on the Web Portal; Enforce account lockout policies; Use CAPTCHA for login attempts

Policy Store Manipulation

TAMPERING

MEDIUM

Malicious Insiders, with access to the Admin Console, can modify unauthorized roles in the Policy Store which leads to privilege escalation for non-privileged users, negatively impacting the Policy Store.

Target: Policy Store · **Source:** Admin Console

Vector: Internal Network

Impact: Critical

Mitigations: Implement Multi-Party Authorization (4-eyes principle) for policy changes; Enable granular RBAC for Admin Console access; Audit all policy change events

Audit Log Deletion/Modification

REPUDIATION

LOW

Compromised Admin, with high-level system privileges, can delete or alter entries in the Audit Log which leads to the inability to trace malicious actions, negatively impacting the Audit Log.

Target: Audit Log · **Source:** Admin Console

Vector: Internal Network

Impact: High

Mitigations: Use Write-Once-Read-Many (WORM) storage for logs; Stream logs in real-time to a separate, isolated security zone; Implement cryptographic signing of log entries

Token Leakage via Intercepted API Request

INFORMATION DISCLOSURE

MEDIUM

External Adversaries, with Man-in-the-Middle (MitM) capabilities, can intercept forwarded API requests containing user tokens which leads to session hijacking, negatively impacting the API Gateway.

Target: API Gateway · **Source:** User Browser

Vector: Internet

Impact: High

Mitigations: Enforce TLS 1.3 for all communications; Use Certificate Pinning for mobile/thick clients; Implement short-lived JWTs and rotation

MFA Bypass via Provider Spoofing

SPOOFING

LOW

Third-Party Risk, via a compromised MFA Provider integration, can send fake 'Success' signals to the IAM Service which leads to MFA bypass for attackers, negatively impacting the IAM Service/IAP.

Target: IAM Service/IAP · **Source:** MFA Provider

Vector: Identity Services

Impact: Critical

Mitigations: Use signed webhooks/callbacks from the MFA Provider; Implement IP whitelisting for MFA provider callbacks; Validate provider certificates

Policy Store Resource Exhaustion

DENIAL OF SERVICE

MEDIUM

External Adversaries, by sending a flood of complex role-lookup requests, can overwhelm the Policy Store which leads to a complete denial of authentication services, negatively impacting the Policy Store.

Target: Policy Store · **Source:** API Gateway

Vector: Internal Network

Impact: High

Mitigations: Implement request throttling at the API Gateway; Use caching for frequent policy lookups; Scale Policy Store horizontally

Unauthorized Claim Injection

ELEVATION OF PRIVILEGE

MEDIUM

Credential Thieves, with access to a compromised User Directory, can inject elevated group claims into user profiles which leads to unauthorized access to sensitive resources, negatively impacting the IAM Service/IAP.

Target: IAM Service/IAP · **Source:** User Directory/LDAP

Vector: Identity Services

Impact: Critical

Mitigations: Implement strict schema validation for directory attributes; Use least-privilege access for the IAM Service's directory connection; Regularly audit user group memberships

Admin Console Session Hijacking

SPOOFING

MEDIUM

Credential Thieves, with access to a hijacked administrator session, can impersonate an admin to update roles which leads to full system compromise, negatively impacting the Admin Console.

Target: Admin Console · **Source:** User Browser

Vector: Internet

Impact: Critical

Mitigations: Enforce session timeouts and re-authentication for sensitive actions; Use secure/HttpOnly/SameSite cookies; Implement IP-based session binding

Unauthorized Role Escalation via Policy Manipulation

ELEVATION OF PRIVILEGE

MEDIUM

A Compromised Admin, given access to the Admin Console, can modify policies in the Policy Store to grant high-privilege roles to a standard user, which leads to unauthorized administrative access, negatively impacting the System Overview.

Target: System Overview · **Source:** Admin Console

Vector: Application Logic / Administrative Interface

Impact: High

Mitigations: Implement Multi-Party Authorization (MPA) for policy changes; Enforce Just-In-Time (JIT) privileged access; Strict RBAC for the Admin Console itself

Credential Harvesting via Web Portal Proxy

SPOOFING

MEDIUM

External Adversaries, given a Man-in-the-Middle (MitM) position between the User Browser and Web Portal, can intercept and spoof login credentials, which leads to account takeover, negatively impacting the System Overview.

Target: System Overview · **Source:** User Browser

Vector: Network Interception

Impact: High

Mitigations: Enforce HSTS and TLS 1.3; Implement Certificate Pinning; Use secure, HttpOnly, SameSite cookies

LDAP Attribute Injection

TAMPERING

LOW

Malicious Insiders, given access to the User Directory, can tamper with group attributes or LDAP fields, which leads to the IAM Service granting incorrect permissions to unauthorized users, negatively impacting the System Overview.

Target: System Overview · **Source:** User Directory/LDAP

Vector: Data Integrity Attack

Impact: High

Mitigations: Read-only access for IAM Service to LDAP; Input validation on all directory attributes; Regular integrity audits of LDAP records

Audit Log Suppression

REPUDIATION

LOW

Malicious Insiders, given local administrative rights on the logging server, can delete or modify Auth Events in the Audit Log, which leads to an inability to trace unauthorized actions, negatively impacting the System Overview.

Target: System Overview · **Source:** Audit Log

Vector: Log Manipulation

Impact: Medium

Mitigations: Write-once-read-many (WORM) storage for logs; Remote logging to a separate, hardened security zone; Real-time alerting on log deletion attempts

MFA Bypass via Provider Response Manipulation

SPOOFING

LOW

External Adversaries, given the ability to intercept traffic between the IAM Service and the MFA Provider, can spoof a 'Success' response, which leads to bypassing the MFA challenge, negatively impacting the System Overview.

Target: System Overview · **Source:** MFA Provider

Vector: API Response Spoofing

Impact: High

Mitigations: Use signed MFA responses (e.g., JWT or HMAC); Mutual TLS (mTLS) between IAM Service and MFA Provider; IP Whitelisting for MFA Provider callbacks

Policy Store Denial of Service

DENIAL OF SERVICE

MEDIUM

External Adversaries, given a high volume of API requests, can overwhelm the Policy Store with queries, which leads to a failure in Access Decisions and system-wide lockout, negatively impacting the System Overview.

Target: System Overview · **Source:** API Gateway

Vector: Resource Exhaustion

Impact: High

Mitigations: Implement rate limiting on the API Gateway; Implement caching for frequently accessed policies; Auto-scaling for the Policy Store backend

Colophon

Maestro'D ThreatModeling

Copyright 2026 Maître D and contributors

Inspired by AWS Threat Designer (<https://github.com/awslabs/threat-designer>), licensed under the Apache License 2.0.

Envisioned by Dirk Verstraete (Maître D).

Designed and architected with Lead Architect Maestro Data (Cursor agent).

Local model — weapon of choice: Gemma 4 12B (coding and threat modeling).

This project is not affiliated with or endorsed by Amazon Web Services, Inc.

Report generated 2026-06-09 19:57 UTC · Model e6821066-576c-47b2-89c8-69bf131e439b